

Advanced Cryptography Solutions

Mock Examinations 2025

Note

This paper is marked out of 100.

Question 1

- (a) A colleague is confronted with the concept of secret sharing. Reading up on secret sharing, they discovered a link with one-time encryption, and are now confused regarding several statements (see below).

Comment on the validity of each statement (correct, incorrect/misleading) and explain (briefly) why they are either correct or incorrect/misleading.

- A.** A modern block cipher offers better security guarantees because it has longer keys than the one-time pad.
- B.** Shamir $(2, 2)$ secret sharing of a message m when implemented in $\mathbb{Z}_2$ is the same as Boolean $(2, 2)$ secret sharing in $\mathbb{Z}_2$.
- C.** In the Real vs Random security game, the adversary can ask for the internal randomness of a scheme.
- D.** Perfect indistinguishability of shares implies that an adversary with infinite computing power cannot learn any additional information about the secret after seeing at most t (threshold) shares.

[12 marks]

- (b) Your friend is impressed by your understanding of cryptography. They have come across the concept of Real-Random security for one time encryption, and want your help with it in the context of a clearly insecure encryption scheme that is based on randomly rearranging the letters that represent a message $\mathbf{m}$.

For efficiency reasons, the scheme requires any message to be of even length. Then a one time permutation is sampled from the space of all permutations with length $|\mathbf{m}|/2$, and the ciphertext is derived via the repeated application of the permutation $\mathbf{c}_{k_i} = \mathbf{m}_i$ to both halves of the message. The encryption scheme is defined in the listing below.

For instance, assume the plaintext $abcde fghij$ is meant to be encrypted. Then a valid key would be $\mathbf{k} = \{2, 3, 1, 4, 5\}$, i.e. $\mathbf{k}_1 = 2, \mathbf{k}_2 = 3$, etc., and thus the corresponding ciphertext would be $cabde hfgij$.

```

 $\mathcal{K}$  = All Permutations of  $\{1, 2, \dots, |\mathbf{m}|/2\}$ 
def KeyGen( $\mathcal{K}$ ) :
     $\mathbf{k} \xleftarrow{s} \mathcal{K}$ 
    return  $\mathbf{k}$ 
def Enc( $\mathbf{k}, \mathbf{m} = m1 || m2$ ) :
    for  $i = 1$  to  $l/2$  :
         $c1_{\mathbf{k}_i} = m1_i$ 
    for  $i = 1$  to  $l/2$  :
         $c2_{\mathbf{k}_i} = m2_i$ 
    return  $\mathbf{c} = \{c1 || c2\}$ 
def Dec( $\mathbf{k}, \mathbf{c} = c1 || c2$ ) :
    for  $i = 1$  to  $l/2$  :
         $m1_i = c1_{\mathbf{k}_i}$ 
    for  $i = 1$  to  $l/2$  :
         $m2_i = c2_{\mathbf{k}_i}$ 
    return  $\mathbf{m} = \{m1 || m2\}$ 

```

Listing 1: Masking based encryption

- Give the Real and Random world for this scheme (as defined in the lectures/hand-out).
- Show via an example how the Real and Random Worlds can be distinguished by an adversary.
- Explain, in your own words, what intuition/security guarantee the Real vs. Random game captures.
- Explain, in your own words, in the context of one-time encryption, what an active and what a passive adversary is, and which adversary the Real vs. Random world assumes.

[12 marks]

- (c) Your friend is now tasked to set up of a secret sharing scheme for their company. The company has s subsidiaries, each with a nominal head, a board with b members, and a single personnel representative. There are more board members than there are subsidiaries, i.e. $b > s$. For major personnel decisions, a majority in a voting like process must be achieved. The voting like process is implemented by reconstructing a secret string, via recombination of sufficiently many shares from a (t, n) secret sharing scheme. The share distribution must satisfy the following properties
- Each head of a subsidiary must at least have one share, and all heads receive an equal number of shares.

- Each board member must have exactly one share.
- The heads of the subsidiaries jointly must have more shares than all board members combined.
- The personnel representative must be able to veto any decision, and therefore must have as many shares as the board members and heads combined.

They wish to share out a secret code that consists of 4 numbers (ranging from 0, ..., 9), for instance a code could be 0123.

- A.** How many shares must each of the subsidiaries heads' receive, and how many shares must the personnel representative receive, given the stated constraints? How many shares are given out in total? **[5 marks]**
- B.** Explain how to set up a Shamir secret sharing scheme. Specifically, state what is suitable threshold t given the setting described above, how many shares n must be given out, what is the degree d of the polynomial, what is the size of the modulus? How are the shares generated? **[5 marks]**

Model answer / LOs / Creativity:

- (a) One point for correctly deciding if a statement is correct or incorrect/misleading. Two points for a succinct argument.

Hint: you should always write down explicitly either correct or incorrect/misleading. I will give one point just for getting this correctly (which you may manage, even if you have no clue, with probability 1/2). Then write down, in a sentence or two why this is.

- A.** Incorrect/misleading. Key length is not relevant for perfect secrecy.
- B.** Incorrect. Call the secret message m . The shares in Shamir scheme, if instantiated over $\mathbb{Z}_2$ we have the polynomial $f(x) = m \oplus a_1x$. If we then produce two shares for $x = 1$ and $x = 2$ then we get $s_2 = m$ and $s_1 = m \oplus a_1$, because $x = 2 \equiv 0 \pmod{2}$. Notice that this leaks m via the first share. In Boolean secret sharing we have $s_1 = a_1$ and $s_2 = m \oplus a_1$.
- C.** Incorrect. Internal randomness, such as the one time key, is never given to the adversary because doing so would make the game trivial to win and one would not give the key to the adversary in the real world either, for obvious reasons.
- D.** Incorrect. t shares allow reconstructions, $t - 1$ shares do not.
- (b) Real vs. Random world: Real takes in as input the message and then applies the encryption scheme (the decryption function is not used), and Random also takes in the message, but simply randomly samples two permutations of

letters with length $l/2$, concatenates them, and gives them as output. A single sampled permutation would also be o.k.

Example $m = aaaaaaaaa$. If the Real world is called then the ciphertext is again $aaaaaaaaa$. If the Random world is called then with high probability at least one of the letters would not be an a . [Note: I did not specify message/key/ciphertext space, so you can choose freely.]

Active adversary gets some help, e.g. they might be able to interact with the encryption oracle with some chosen inputs, whereas a passive adversary gets no help. The Real vs Random game, as we defined it, assumes a passive adversary.

- (c) **A.** Each board member gets exactly one share, so there are b shares for them. There are more board members than subsidiaries s , so $b > s$. In order to ensure that the subsidiaries in total have more shares than the board members, each subsidiary must get $c = \lceil \frac{b}{s} \rceil (+1)$ shares (one could do this differently as well like saying that each subsidiary must get $b + 1$ shares) (the $+1$ applies if b is a multiple of s). The personnel rep must get $b + cs(+1)$ shares
- B.** There must be $n = 2(b + cs)(+1)$ shares, the threshold must be $t = b + cs(+1)$. Therefore the degree of the polynomial must be $t - 1$. In order to encode a secret four digit number as a_0 of the polynomial, the modulus p must be larger than 10^4 . The other coefficients must be sampled uniformly modulo p . The share for party i is $f(i)$.

Part A of the question requires some understanding and creativity. But part B is purely book work: even if you have no clue about A, you can still provide a complete answer for B by simply explaining how to set up Shamir. This means you must say that n is the total number of shares, t is the threshold, etc (see the model answer).

Question 2

You have been head-hunted by a large car manufacturer. They now wish to deploy strong cryptography, and at the same time, they wish to secure their wireless key fob against side channel attacks: their key fob stores/uses one of a few static keys. As they are a “forward looking” company, they decided that it is time to (at least) upgrade to using the DES algorithm. They need your expertise to make an informed choice about the implementation of countermeasures.

DES was designed specifically for hardware implementations, and can run in very resource constraint environments. It has a small state (64 bits). At the beginning of a DES round, half of the state is exclusive-ored with a round key (akin to what happens in the AES `AddRoundKey` function). Then the state is expanded and 8 different substitutions $S_i()$ are applied to six bits of the state. The substitutions are “compressing” and give a four bit output. Then the state bits are permuted again. The whole process is depicted in Fig. 1.

- (a) Explain the five steps for a differential input attack. **[15 marks]**
- (b) Reason what side channels are a particular threat to a key fob. **[6 marks]**
- (c) DES has eight different substitution boxes, and, it does bit-wise permutations. What hiding strategies would you recommend ? **[4 marks]**
- (d) The company also approached you with several questions, where they wish clarification:
 - A.** They heard that you need at least a (3,3) Boolean secret sharing scheme to achieve security against differential input attacks. Is this true? What security guarantee(s) does a (3,3) Boolean secret sharing scheme give? **[4 marks]**
 - B.** They are aware of the 3 – *DES* construction (i.e. doing DES three times with either two or three keys), and wonder if 3 – *DES* would increase the number of needed traces for a differential input attack by a factor of 3? **[3 marks]**
 - C.** They also consider strengthening DES by running it with more rounds. Would this make the algorithm harder to attack using side channels? **[3 marks]**

Model answer / LOs / Creativity:

- (a) Five steps: choosing intermediate value, record traces, compute hypothetical intermediates for all key guesses, map intermediates to leakage using leakage model, apply distinguisher. Must briefly explain what each step is about. Notice that 15 points are given, so clearly you should demonstrate your knowledge here.
- (b) Physical side channels, like power, timing, EM, because the adversary may be in possession of the key fob. Power: the adversary may extract the internals, and thus

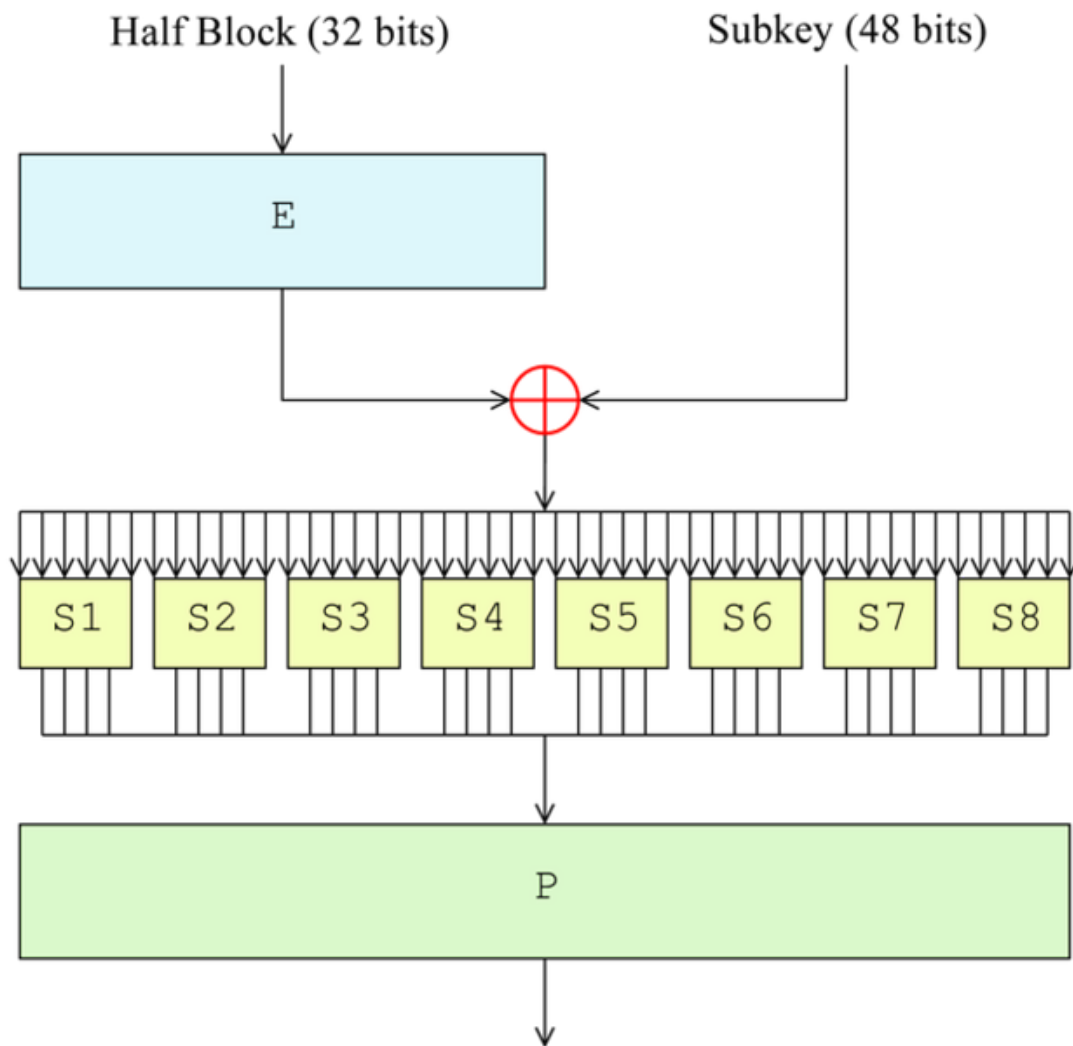


Figure 1: DES round

may be able to make contact and measure power. EM: the adversary should be able to measure this perhaps most easily. Timing: needs perhaps also to make physical contact, as getting precise measurements is not easy when the just pressing the fob. Perhaps power measurements can also reveal timing information here.

- (c) If implemented in hardware: dummy rounds, or a less leaky logic style. Changing the order of the DES round functions is not possible, and they are mostly bit permutations which cannot be changed once they are implemented in hardware. Perhaps one could run through the S-box randomly, but this would not impact on the rest of the round.

If implemented in software: could do bit wise permutations in different orders, could add dummy rounds and perhaps dummy permutations. Could do substitution boxes in arbitrary order.

- A.** Wrong. A (2,2) secret sharing scheme suffices, assuming what takes care of potential HD leakage. A (3,3) scheme would give a security guarantee against an adversary that combines 2 shares, aka trace points (i.e. no attack like this will ever work, regardless of how many traces are used), and it gives computational guarantees against an adversary that combines three trace points, they will need roughly n^3 traces (compared to an akin attack if there was no countermeasures that used n traces) to be successful.
- B.** No. Such a construction would need to recover twice or three times the key material. However, the number of traces for key recovery might not increase at all, only the number of attacks needs to increase and perhaps the effort to find suitable time points.
- C.** No. The number of rounds is not a relevant factor for the attack complexity, unless the number of extra rounds would be randomly decided. Then this would be akin to a hiding countermeasure.

Question 3

This question is about multi-party computation (MPC).

- (a) What is MPC used for in practice? What security guarantees are expected (consider passive and active adversaries)? **[10 marks]**
- (b) An MPC solution for the private computation over the input values of n clients is being designed using a $(2, 3)$ Shamir secret sharing scheme. The function that is being computed is a weighted sum over the clients inputs m_i : $s = \sum_{i=1}^n i \cdot m_i$. There seems to be a problem with the implementation of the MPC addition in one of the parties. Here is a snap shot of an exemplary computation for $n = 4$ clients. You can see the shares that each party has, and the weighted sum that they have computed. One party's weighted sum is wrong (determine this party). Correct their mistake to compute the final weighted sum. You can use the public recombination vectors. These are for parties $(P_1, P_2) = (2, 22)$, $(P_1, P_3) = (13, 11)$, $(P_2, P_3) = (3, 21)$. All computations happen over $\mathbb{Z}_{23}$: is this a well chosen modulus? **[8 marks]**

Value	P_1	P_2	P_3
m_1	3	5	7
m_2	7	12	17
m_3	4	5	6
m_4	7	10	13
$\sum_i i \cdot m_i$	11	16	19

- (c) Comment on the validity (correct vs incorrect/misleading) of the following statements about the BGW protocol for secure computation. Briefly explain your reasoning.
- A.** The BGW protocol cannot be used when inputs are floating point numbers. **[3 marks]**
- B.** If a multiplication with a constant needs to be carried out, then all parties must communicate to reduce the degree of the resulting polynomial. **[3 marks]**
- E.** The BGW protocol is computationally secure. **[3 marks]**

Model answer / LOs / Creativity:

- (a) MPC is used when multiple distrusting parties want to jointly carry out a computation, where each party contributes some input data. Because parties are distrusting, they do not wish to share their inputs with other parties, or even, reveal any information about their inputs to the other parties. Practical applications today include privacy preserving machine learning, or private aggregation tasks.

The main security property that we expect any concrete MPC scheme to fulfill is called input privacy. Informally speaking, this means that P_i parties (with inputs X_i)

want to compute some function $F(X_1, \dots, X_n) = z$ such that only z is learned by the P_i but nothing else is learned about the X_i . The word “else” is important: some information about the inputs X_i can be known to the parties (e.g. it might be public knowledge that the inputs are all 4 digit integers).

One or multiple adversaries may attack the party, and we say that one or more adversaries can “corrupt” the party. The worst case would be if there are multiple adversaries that collaborate: this is why we generally speak about a single adversary who may corrupt multiply party. Some MPC protocols have a special party called the dealer. An adversary may also corrupt a dealer. When an MPC protocol runs and some parties are corrupted then there are two behaviours for the non-corrupt parties. One type of behaviour is that the MPC protocol still ensure that non-corrupt parties still get a correct result, this is called “robust MPC”. The other behaviour is if a non-corrupt party aborts the protocol and outputs nothing. This is called “MPC with abort”.

Adversaries can be either passive or active. A passive adversary corrupts parties and so knows all their internal randomness, but they cannot change their behaviour. Passive adversaries are also called “semi-honest adversaries”. An active adversary corrupts parties and not only knows their internal randomness but also changes their protocol messages. They are also called “malicious adversaries”.

Hint: the fact that 10 points are awarded implies that you should try and write a decent amount of text. In particular, because the question asks specifically for “security guarantees” you should be prepared to write about more than one. When you discuss adversaries, ensure to write what their capabilities are, and what their goals are. Ensure to demonstrate your knowledge of jargon terms. They are typically typeset inside of boxes in the lecture notes.

- (b) Hint: To identify the party that has the incorrect weighted sum you need to compute the weighted sum (mod 11) for each party. In the example it is P_2 which shows an incorrect result, it should be 15. You can then use any of the given public recombination vectors to get the actual result, e.g. using $r = (2, 22)$ you get $11 \cdot 2 + 15 \cdot 22 \pmod{23}$. Working this out then gives $22 + (220 + 70) \equiv 22 + (13 + 1) \equiv 26 \equiv 3$. This is clearly weird and show that there is another problem with how this was set up: the weighted sum clearly exceeds the modulus. So the modulus, although prime, is not well chosen for the computation that is intended.

This is again a question that carries many points, because it is a bit more time consuming than questions that just want short answers. Just writing down how to get the sum via one of the recombination vectors is fine (I will not mark you down for a mistake in the modular arithmetic). Noticing that the result is kind of “two small” to be the sum of four parties (although the text does not make it clear that the m_i must be larger than 0, but it also gives no upper limit for m_i either), and then noticing that really for arbitrary m_i , the value 23 is a bit small, also gives points. But if you made the argument without basing it on the example, then this would be fine too.

- A.** Wrong. There are ways by which one can convert floating point representations to integers.
- B.** Wrong. This is a linear operation and therefore can be done locally.
- C.** Wrong/misleading. The protocol offers perfect indistinguishability of shares/no additional information about shares given the final result. This is independent of computational ability of an adversary.